

# M 109: Broken SSL (30 pts extra)

## What You Need for This Project

- An Android emulator such as Genymotion
- Burp proxy

## Summary

Many Android app sends login credentials over broken HTTPS, without verifying the SSL certificate.

This is such a serious security flaw that the [FTC punished Fandango and Credit Karma for doing the same thing in 2014](#).

## Adjusting Android Networking to Bypass the Proxy

While Burp is useful, most of the time you want to bypass it so you can get to Google Play.

From the Android home screen, click the circle at the bottom center.

Open **Settings**.

In Settings, click "**Network & internet**".

Click **Wi-Fi**.

Click **AndroidWiFi**.

Click **Advanced**.

In the "Network details" screen, at the top right, click the **Pencil** icon.

In the "Proxy" field, click the down-arrow.

Click **None**.

Then click **Save**.

## Installing Firefox

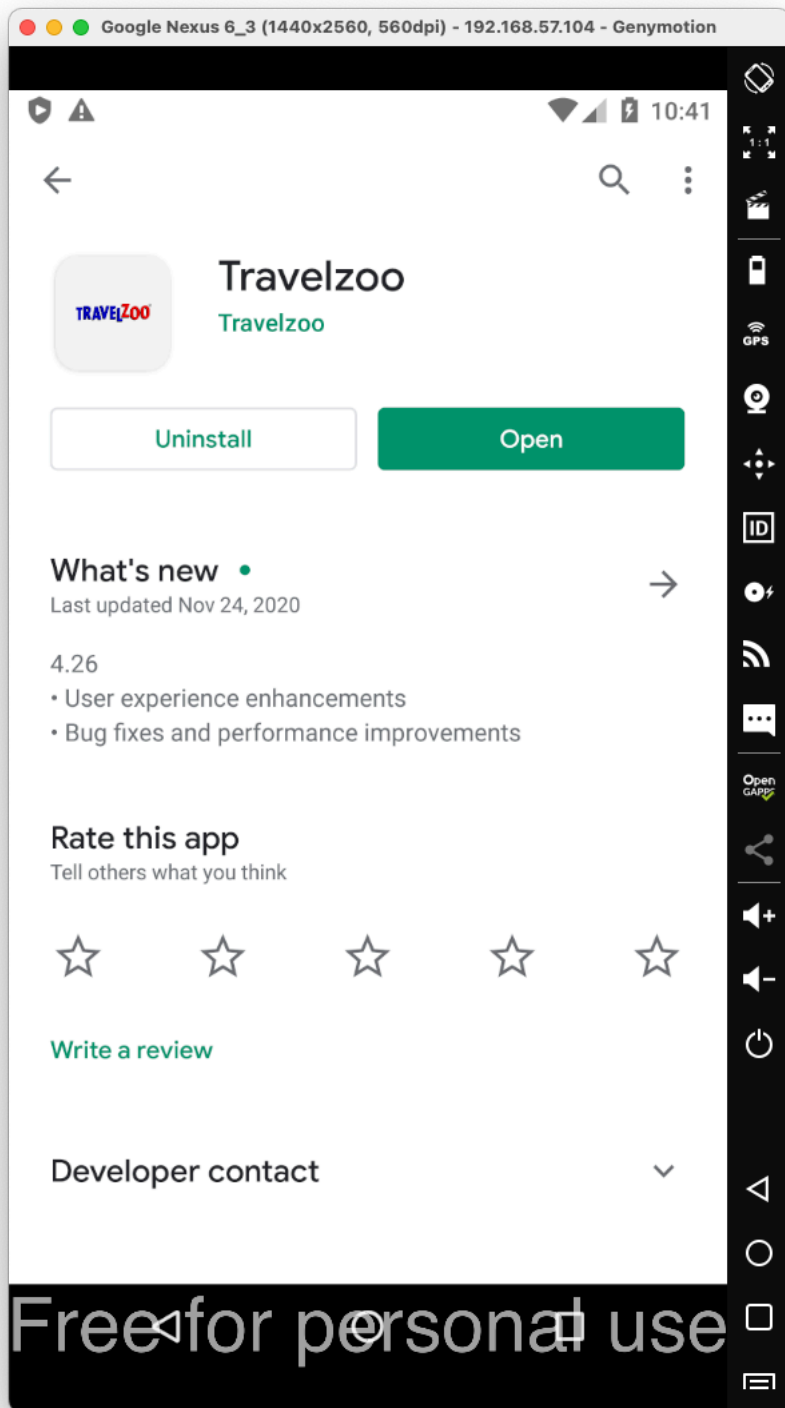
If you don't already have Firefox installed, install it from Google Play.

## Installing the Travelzoo Android App

Open Google Play and search for **travelzoo**.

Install the app, as shown below.

If you can't get the app from Google Play, download [my archived copy](#).



## Adjusting Android Networking to Use the Burp Proxy

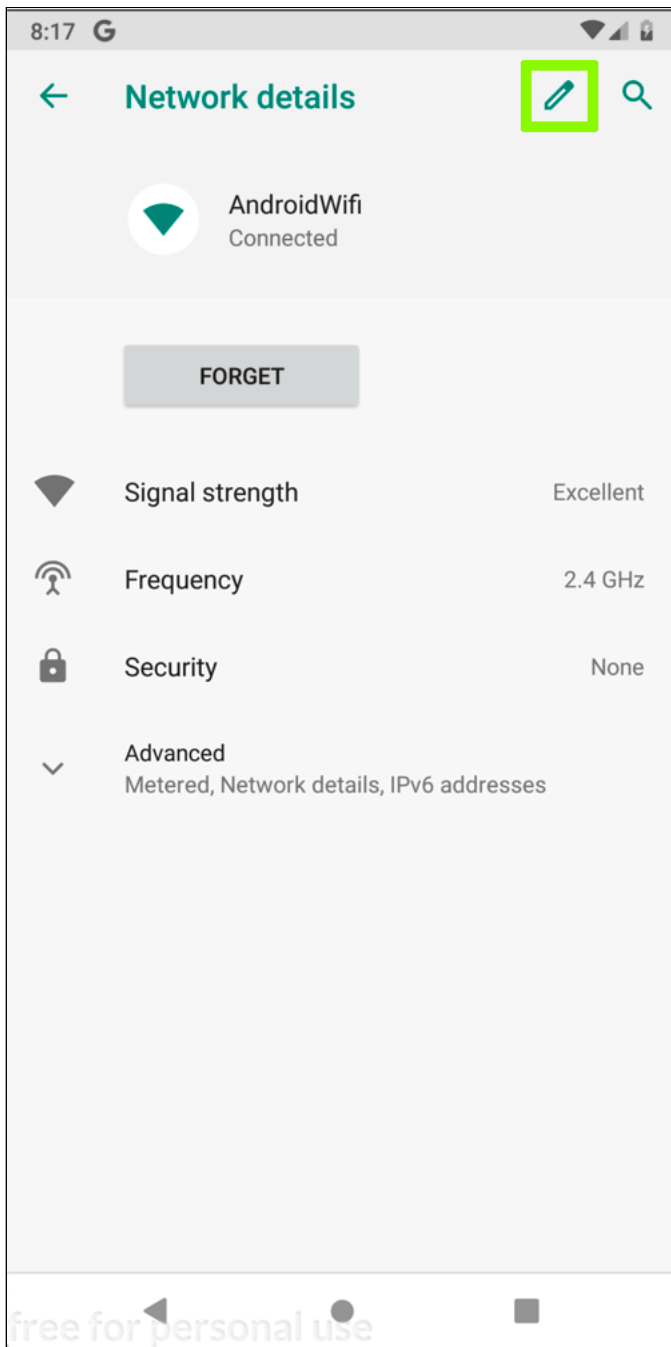
On your Android device, in Settings, click "**Network & internet**".

Click **Wi-Fi**.

Click **AndroidWiFi**.

Click **Advanced**.

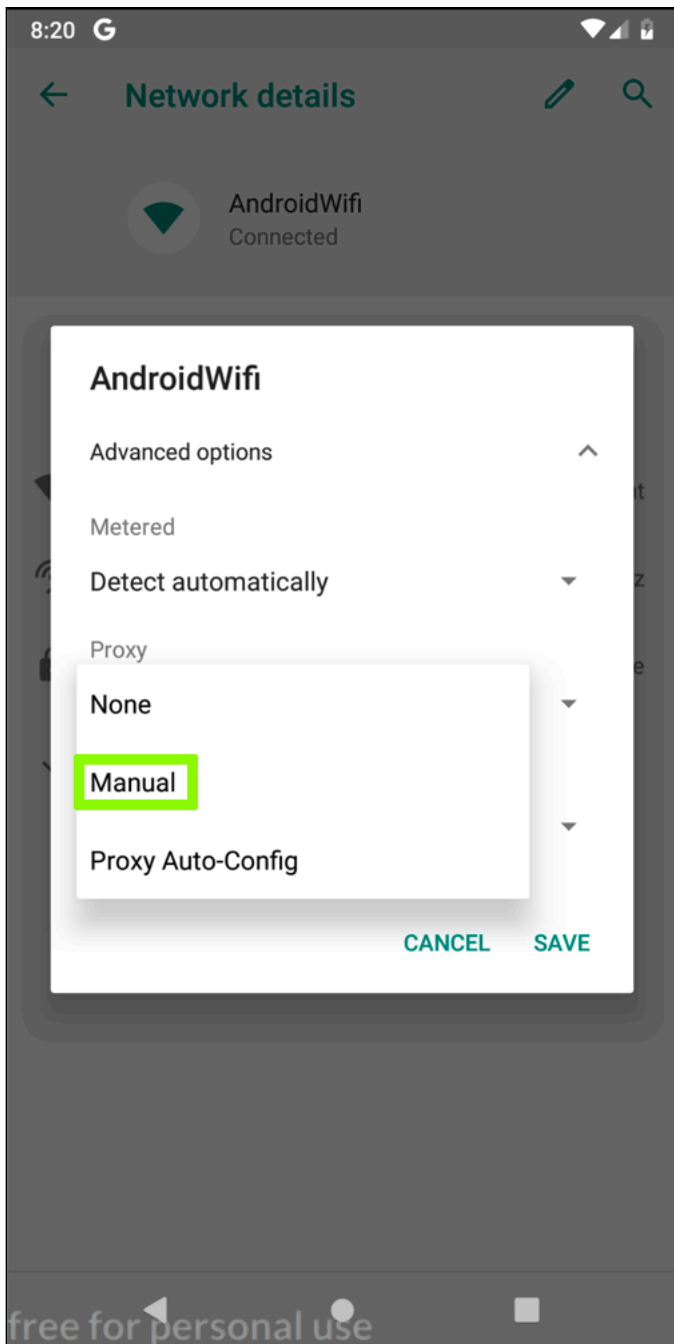
In the "Network details" screen, at the top right, click the **Pencil** icon, outlined in green in the image below.



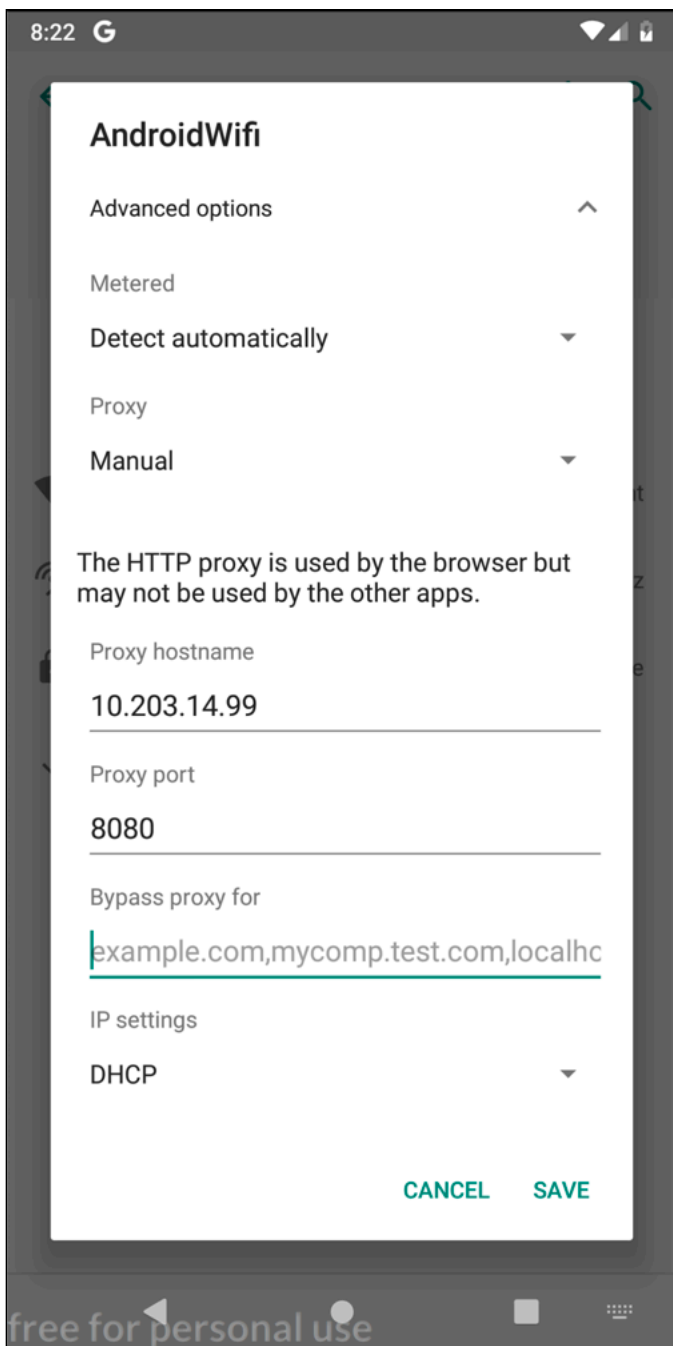
In the "AndroidWifi" box, in the "Advanced options" row, click the down-arrow.

In the "Proxy" field, click the down-arrow.

Click **Manual**, which is outlined in green in the image below.



Enter the IP address and port number of the Burp proxy listener, as shown below.



On your Android device, click **SAVE**.

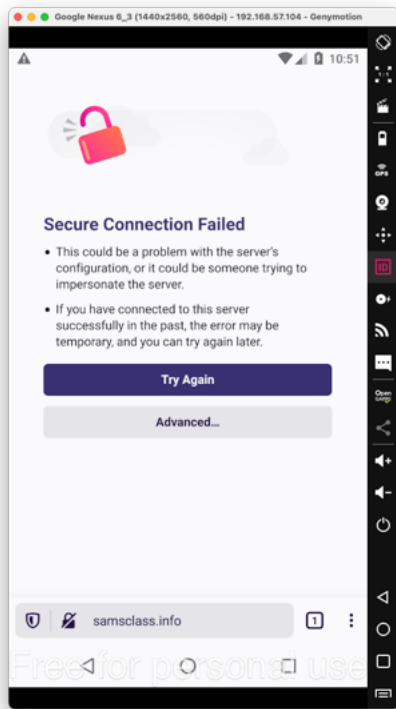
At the bottom center of the device, click the round **Home** button.

## Testing a HTTPS Connection

Open Firefox. Go to <https://samsclass.info>

You should see an error message, as shown below. If you don't, remove the Portswigger certificate, with the steps in the gray box below.

This happens because Burp is performing a man-in-the-middle attack and Firefox notices it.



## Removing the PortSwigger Certificate

On your Android device, in Settings, click "**Security & location**", **Advanced**, "**Encryption & credentials**", "**Clear credentials**".

Click **OK**.

Enter your PIN.

## Observing the HTTPS Traffic

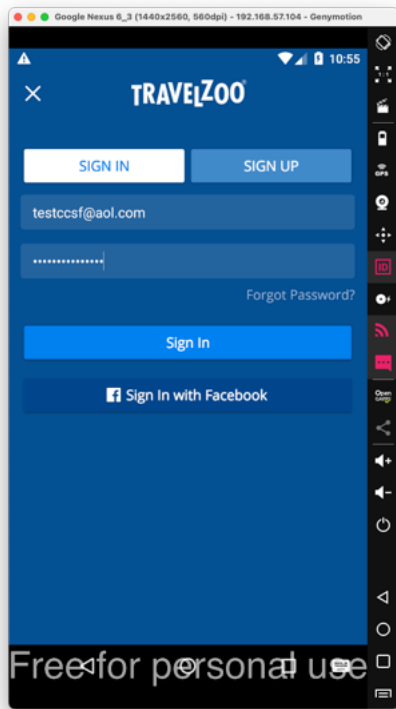
Open the Travelzoo app.

At the lower right of the home page, click the head icon.

Click the "**Sign In or Sign Up**" button.

Click the "**SIGN IN**" button.

Enter an email address and password, as shown below, and click the "**Sign In**" button.



In Burp, on the Proxy tab, click the "**HTTP Requests**" sub-tab.

Find the POST method going to travelzoo.com.

The username and password appear in Burp, as shown below:

### M 109.1: Parameter Name (10 pts)

Find the text covered by a green box in the image below. That's the flag.

The screenshot displays the Burp Suite Community Edition v2021.2 interface. The top menu bar includes options like Comparer, Extender, Project options, User options, and SAML Raider Certificates. The 'HTTP history' tab is active, showing a list of intercepted requests. The first request (ID 24) is highlighted, showing a POST to `/SecureLocalDealsServices.svc/Members/SignIn` from `https://ssl.localws.travelzoo.com`. The 'Request' pane shows the raw HTTP request details, including headers like `Accept: application/json`, `User-Agent: Travelzoo Android App v.4.26 / WS 2.10`, and the body containing login credentials. The 'Response' pane shows the raw HTTP response details, including status `200 OK` and headers like `Content-Type: application/json`, `Server: Microsoft`, and `Set-Cookie: ASP.NET_SessionId=...`. The 'Inspector' pane is visible on the right side.

| #  | Host                              | Method | URL                                               |
|----|-----------------------------------|--------|---------------------------------------------------|
| 24 | https://ssl.localws.travelzoo.com | POST   | /SecureLocalDealsServices.svc/Members/SignIn      |
| 25 | https://services.travelzoo.com    | GET    | /v1/content/refundreasons?Source=Android&Versi... |

**Request**

```
1 POST /SecureLocalDealsServices.svc/Members/SignIn
2 HTTP/1.1
3 Accept: application/json
4 User-Agent: Travelzoo Android App v.4.26 / WS 2.10
5 Content-Type: application/x-www-form-urlencoded
6 Content-Length: 114
7 Host: ssl.localws.travelzoo.com
8 Connection: close
9 Accept-Encoding: gzip, deflate
10 Source=Android&Version=2.10&testccsf%40aol.com&Password=testpassword123&tzLocale=1&tzMessagesLocale=1
```

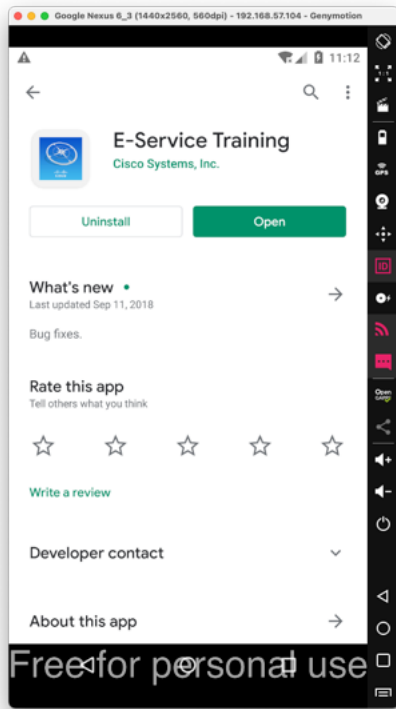
**Response**

```
1 HTTP/1.1 200 OK
2 Content-Type: application/json
3 Server: Microsoft
4 X-Powered-By: ASP.NET
5 X-IP: 10
6 Content-Length: 114
7 Expires: Wed, 10 Feb 2021 10:00:00 GMT
8 Cache-Control: no-cache
9 Pragma: no-cache
10 Date: Wed, 10 Feb 2021 10:00:00 GMT
11 Connection: close
12 Set-Cookie: ASP.NET_SessionId=...
```

## Cisco E-Service Training

**WARNING:** this app no longer allows a login through Burp, as of 5-12-2021. So I recommend skipping the Cisco app. Install the app, as shown below.

If you can't get the app from Google Play, download [my archived copy](#).



Enter any email and click the **Next** button.

Enter any password and click the **"Sign In"** button.

## M 109.2: Server Name (10 pts)

In Burp, find the text covered by a green box in the image below. That's the flag.

Burp Suite Community Edition v2021.2 - Temporary Project

Filter: Hiding CSS, image and general binary content

| #   | Host                            | Method | URL                                                   |
|-----|---------------------------------|--------|-------------------------------------------------------|
| 294 | https://col.eum-appdynamics.com | POST   | /eumcollector/beacons/browser/v2/AD-AAB-AAT-...       |
| 295 | https://[REDACTED].cisco.com    | POST   | /api/tenants/global/v1/am/login-actions/authentica... |

**Request**

Pretty Raw \n Actions

```
s=1612999055570&r=https%3A%2F%2Fidentity.cisco.com%2Fapi%2Ftenants%2Fglobal%2Fv1%2Fam%2Flogin-actions%2Fauthenticate%3F1831657059
X-Requested-With: com.cisco.estmobiledemo
username=test2233%40aol.com&password=P%40ssw0rd&cliData=%7B%22dWFn%22%3A%22Mozilla%2F5.0+%28Linux%3B+Android+4.4%3B+Nexus+4+Build%2FKRT16H%29+AppleWebKit%2F537.36%2
```

**Response**

Raw Renc \n Actio

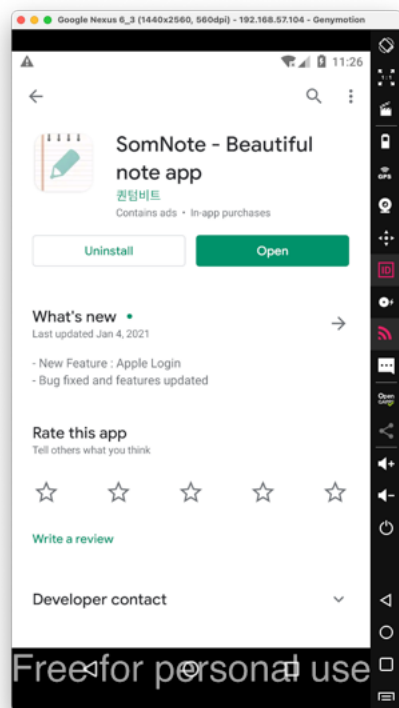
```
1 HTTP/1.1 200 OK
2 Content-Type: t
3 Cache-Control:
4 X-XSS-Protection:
5 X-Frame-Options:
6 Content-Security-Policy:
7 X-Robots-Tag: n
8 Strict-Transport-Security: max-age=31536000
```

0 matches

## Somnote

Install the app, as shown below.

If you can't get the app from Google Play, download [my archived copy](#).

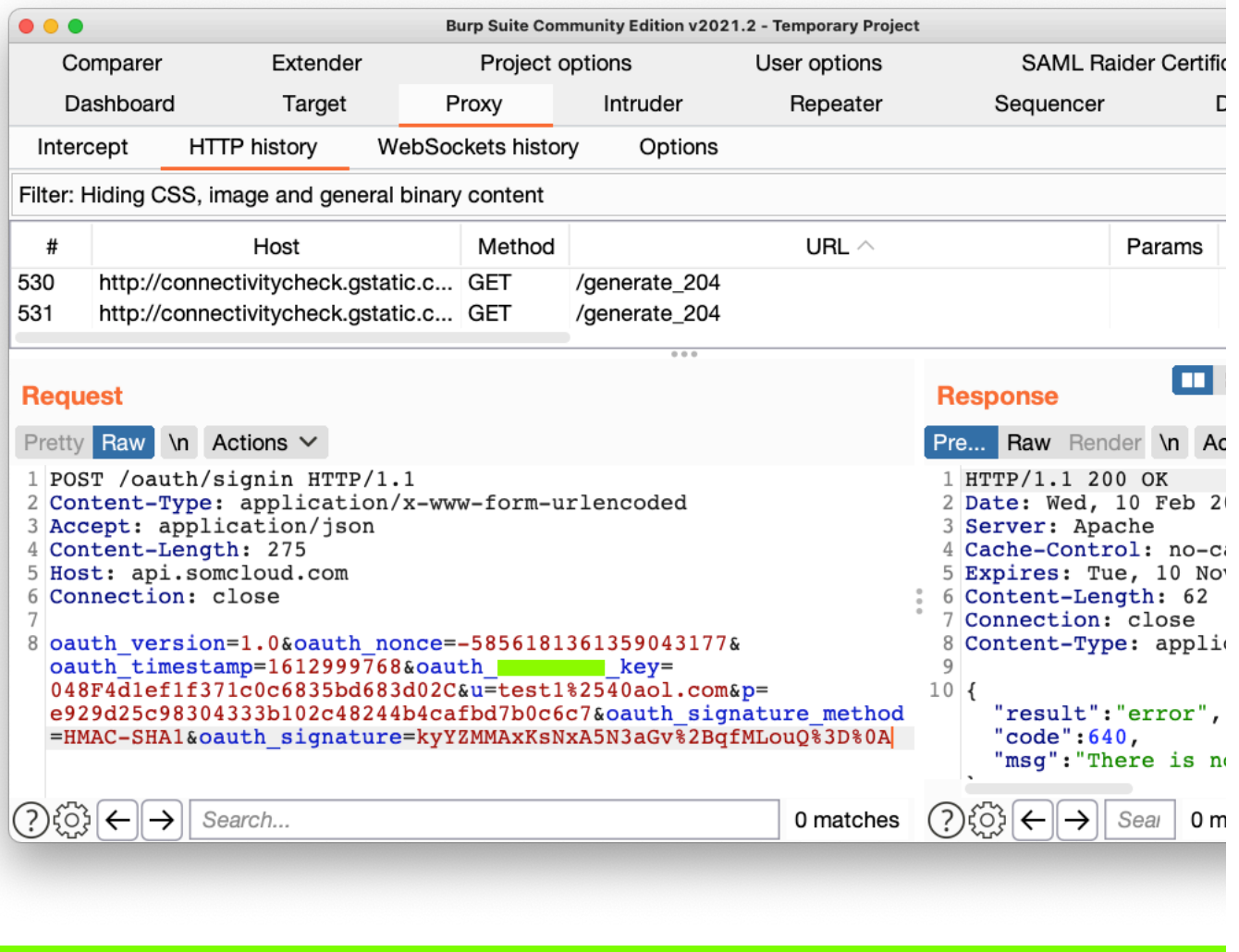


Launch Somnote. If it asks for permissions, grant them.

Click "**LOGIN WITH EMAIL**", and enter any email and password, and click the **Login** button.

### M 109.3: Parameter Name (10 pts)

In Burp, find the text covered by a green box in the image below. That's the flag.



## Responsible Disclosure

I notified all these companies of this problem years ago:

- [Travelzoo](#)
- [Cisco](#)
- [Somnote](#)

Posted 2-10-21  
Note about Cisco App added 5-12-2021